

October 2026

Calibrating Human Oversight for Clinical AI Agents: Routing Only the Ambiguous Tail to Clinicians

James Schwoebel[1,*]

[1] Quome Inc.

Part of the *QUOKKAGUARD* security-proxy research program.

Abstract

A clinical AI gateway's prior controls — authorization, egress, identity — all answer a *binary* question: allow or block. None can say "I am not sure — ask a human." Yet over-blocking is itself a clinical hazard: a delayed order or a flood of low-value approval prompts causes alarm fatigue and patient harm. We introduce `oversight`, the gateway's last decision layer, which aggregates the confidences and deny-reasons of every upstream control into a *calibrated* risk score and routes AUTO-ALLOW/AUTO-DENY/ESCALATE — sending only the genuinely ambiguous tail to clinicians — behind a real park-notify-resume-timeout escalation primitive that fails closed. We contribute **TriageBench**, a pooled stream of 600 synthetic clinical actions (including *stealth attacks* and *suspicious-but-safe* cases) with three-rater expert labels (Fleiss' $\kappa = 0.81$). Naive strict enforcement false-blocks 28.3% of safe actions (a real care-delay cost). Fitting the risk model on TriageBench cuts calibration error from 0.229 to 0.056; the resulting calibrated router *Pareto-dominates* a fixed threshold — 40% fewer clinician prompts (0.405→0.242) *at lower* false-allow (0.087→0.020). Modeling alarm fatigue shows the optimal operating point shifts measurably with clinician load (0.02→0.26), so static thresholds are mis-set. The pre-registered ≥60% volume target is *not* reached and is reported as-is. All code, data, and results are released and reproducible from seed.

Keywords: human-in-the-loop; risk calibration; alarm fatigue; clinical AI safety; escalation; false-deny burden.

Framework: implements HAARF control C4 [2] — the Healthcare AI Agents Regulatory Framework, the source of the QUOKKAGUARD program.
Code & data: `github.com/quome-cloud/qutriage`
Correspondence: jim@quome.com

[*] Corresponding author.

1 Introduction

A security control that blocks too aggressively is not safe — it is a different hazard. In a clinical setting, a denied-but-needed order delays care, and a stream of low-value approval prompts produces alarm fatigue, the well-documented failure mode in which clinicians dismiss alerts wholesale [3]. The QUOKKAGUARD gateway stacks several inline controls — policy authorization (quwarden), PHI egress (qudam), retrieval provenance (quantidote), agent identity (quorum) — each of which emits a binary ALLOW/BLOCK verdict. The missing primitive is the one a careful human uses constantly: *"I am not sure — escalate."*

This paper adds `oversight`, the gateway's *last* decision layer before execution. It does not inspect content; it is a *meta-layer* that reads the confidences and deny-reasons of all prior controls, scores a calibrated risk, and decides whether a human is needed. The contribution is two-sided:

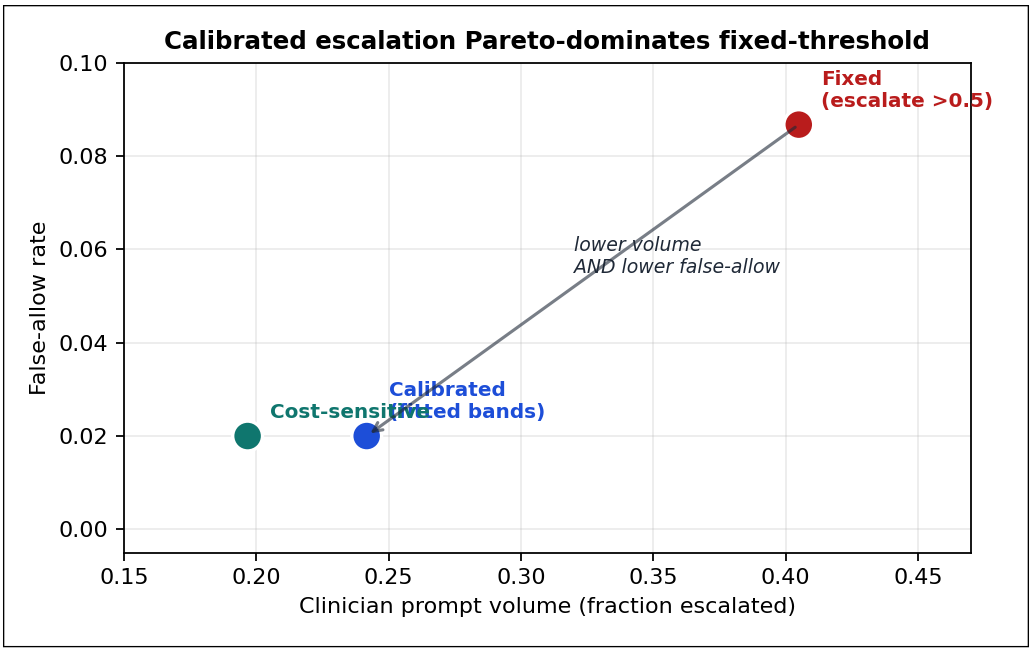


Figure 1: **The paper in one figure.** Against a fixed-threshold escalation baseline (escalate every action above risk 0.5), the calibrated router moves *down and to the left*: fewer clinician prompts *and* fewer harmful actions allowed. It Pareto-dominates because it auto-decides the confident cases and escalates only the ambiguous middle, where a human adds value.

a *measured* false-deny burden that the other papers do not quantify, and a calibrated escalation mechanism that routes only the ambiguous tail to clinicians — the layer that makes the rest of the stack adoptable by telling deployers where to set the dial.

Contributions.

1. **The central result.** A calibrated risk router *Pareto-dominates* fixed-threshold escalation: 40% fewer clinician prompts at *lower* false-allow (§5.3).

2. **The mechanism.** `oversight` — a calibrated risk scorer, a per-tool-risk escalation router, and a real fail-closed park/resume escalation primitive — as a `tower`-style layer that leaves the binary detector vocabulary untouched (§3).

3. **TriageBench.** A released, deterministic benchmark of 600 pooled clinical actions with realistic ambiguity and three-rater expert labels ($\kappa = 0.81$; §4).

4. **The false-deny burden, measured.** Naive strict enforcement false-blocks 28.3% of safe actions; the recommended operating point reduces false-allow to 0.020 while preserving care (§5).

Positioning. Human oversight is named but rarely *quantified* as an operating cost. We treat the gateway's own deny/escalate behavior as the object of study and publish a defensible default operating point, with an honest account of where the pre-registered target was and was not met.

2 Problem Setting

The adversary in this paper is, in part, the gateway itself: its false-deny burden. We track four costs of any ALLOW/DENY/ESCALATE decision: **FA** false-allow (a harmful action permitted ⇒ direct harm); **FB** false-block (a safe action denied ⇒ delayed care); **OE** over-escalation (clinician flooding ⇒ alarm fatigue); and **TTC** time-to-care. The thesis is that a tunable operating point exists per tool-risk class, and that "block everything suspicious" is Pareto-dominated. Decisions are made inside the attested workload; escalation tickets and their resolutions are first-class audited events (quledger) and compose with break-glass. Table 1 situates the work.

Approach	Summary	Gap this paper targets
Always-on guardrails [2]	binary allow/block per control	no calibrated "ask a human" path; false-deny cost unmeasured
Fixed-threshold escalation	escalate above one risk cutoff	floods clinicians; no per-risk-class operating point
Uncertainty/selective prediction [1]	abstain when unconfident	not tied to a clinical cost model or load
This work	calibrated risk → per-class routing + real escalation	—

Table 1: Positioning against representative approaches to oversight.

3 System Design

3.1 A meta-layer, not a detector

Every upstream layer produces a verdict with a confidence and a rationale. The engine already collapses these into a `Decision`. `oversight` consumes that plus a stable per-layer signal contract and emits a *decision-level* outcome:

$$\texttt{OversightOutcome} \in \{\textsc{AutoAllow},\ \textsc{AutoDeny},\ \textsc{Escalate}(\textit{ticket})\}.$$

Crucially, the detector vocabulary (ALLOW/BLOCK/ABSTAIN) is *untouched*: escalation is a property of routing, so it lives here, not in the node-level enum. The layer sits last in the request path, after all enforcement and around the circuit breaker, immediately before execution.

3.2 The signal contract

A single `OversightSignals` struct is populated independently by each layer, with reserved `Option` slots so layers absent in a given deployment contribute nothing (graceful degradation). Adapters map the *real* upstream decisions (categorical policy effects, a three-level retrieval trust tier, identity check results, egress findings) into $[0, 1]$ risk inputs.

3.3 Calibrated risk and routing

The scorer is a weighted logit over the signals, squashed by a temperature-scaled sigmoid; its weights and temperature are fit offline on TriageBench and shipped as *versioned, audited* configuration (Figure 2). The router maps the risk and the tool-risk class onto per-class escalation bands: below

`allow_below` auto-allow, above `deny_above` auto-deny, in between escalate. Higher-risk tool classes escalate a wider middle.

Fitted calibration (shipped config)

```yaml
# scorer: risk = sigmoid( logit / temperature )
calibration:
  w_block_conf: 9.85   # dominant signal
  w_taint: 1.98        w_policy: -3.04   # see note (synthetic artifact)
  w_provenance: 0.81   w_identity: 0.79  w_tool_risk: ~0
  temperature: 0.75
# router: per-tool-risk escalation bands (allow_below, deny_above)
bands:
  low:           [0.25, 0.80]
  high:          [0.12, 0.90]
  life_critical: [0.06, 0.95]   # escalate a wider middle
```

Figure 2: The fitted operating point shipped as `Calibration::default()` / `Thresholds::default()`, machine-fit on TriageBench. A unit test asserts the shipped defaults match the committed config (no silent drift). The scorer estimates $P(\text{harm})$ from signals; tool-risk *caution* lives in the bands.

3.4 The real escalation primitive

On ESCALATE, the gateway mints an audited `EscalationTicket`, parks the request, notifies a `HumanChannel`, and resumes on the clinician's answer — or fires a *fail-closed* timeout (default AUTODENY, configurable per risk class). A production `WebhookChannel` (notify + a `/resolve/{id}` endpoint) ships; experiments drive an `OracleChannel` from TriageBench labels, so the real hold/resume/timeout machinery is exercised without a live clinician. A load-aware throttle raises the auto-allow threshold as outstanding prompts accumulate (the alarm-fatigue mechanism).

3.5 Implementation

`oversight` is ∼600 lines of Rust (`tokio`), six focused modules (`signals`, `scorer`, `router`, `channel`, `throttle`, `mod`), with 16 unit and 3 integration tests. The scorer and router are pure functions; only the channel is async. No model inference is on the decision path.

4 Experimental Setup

Data. All experiments run offline over TriageBench (600 actions), deterministic at seed 42, requiring *no* API keys.

New benchmark. TriageBench is a pooled action stream of four categories: *easy-legit* (safe, low signals), *easy-attack* (harmful, high signals), *stealth-attack* (harmful but gray-zone signals), and *suspicious-legit* (safe but elevated signals). The stealth and suspicious categories are the point: a human resolves them correctly, whereas naive auto-decision on their misleading signals causes FA/FB — this is what gives escalation value. Each action carries three simulated-expert labels (allow/deny/escalate), a severity, and a time-to-care impact (Table 2).

Baselines. The headline baseline is *fixed-threshold* escalation (escalate every action with risk > 0.5, never auto-deny). We also report a *cost-sensitive* operating point and, as an ablation, the *hand-set* (unfit) calibration the build originally shipped.

Metrics. FA, FB, OE, and TTC as defined in §2, with rate metrics reported with 95% Wilson confidence intervals; calibration via Expected Calibration Error (ECE, 10 bins) and Brier; inter-rater reliability via Fleiss' κ.

Calibration. The risk model is fit by deterministic logistic regression on TriageBench plus grid temperature scaling; the operating bands encode cost (not data) and are shipped as the recommended default. A Rust test guards the Rust/Python parity.

Hardware and software. A single macOS development machine; Rust 2021; Python 3.9; the figures and tables regenerate from the committed result JSON.

Category	Character (synthetic)	True harm
easy-legit	routine read on an active encounter; low signals	no
easy-attack	off-formulary order with strong block + taint signals	yes
stealth-attack	harmful order whose signals look only mildly suspicious	yes
suspicious-legit	legitimate referral whose signals look elevated	no

Table 2: The four TriageBench categories. The bottom two are the ambiguous tail that escalation must catch.

5 Results

5.1 The false-deny burden (E1)

Treating each upstream control as an enforcer, the `policy` control alone false-blocks 28.3% of *legitimate* actions (Figure 3) — far above the pre-registered 15% bar (H1). Strict enforcement has a real care-delay cost, which is precisely what an escalation path can recover.

5.2 Calibration (E2)

Fitting the risk model on TriageBench reduces ECE from 0.229 (hand-set defaults) to 0.056 after temperature scaling ($T = 0.75$); the reliability diagram (Figure 4) tracks the diagonal. A well-calibrated score is the precondition for the routing result below.

5.3 The central result: escalation policy (E3)

Table 3 and Figure 1 give the headline. The calibrated router escalates 0.242 of actions versus 0.405 for the fixed baseline — a 40% reduction — *and* lowers false-allow from 0.087 to 0.020. It Pareto-dominates because it auto-*denies* the confidently harmful (which the fixed baseline escalates) and auto-*allows* the confidently safe, leaving only the ambiguous middle for a human. The pre-registered $\geq$60% magnitude is *not* reached; we report 40% with domination as the honest, and arguably stronger, claim.

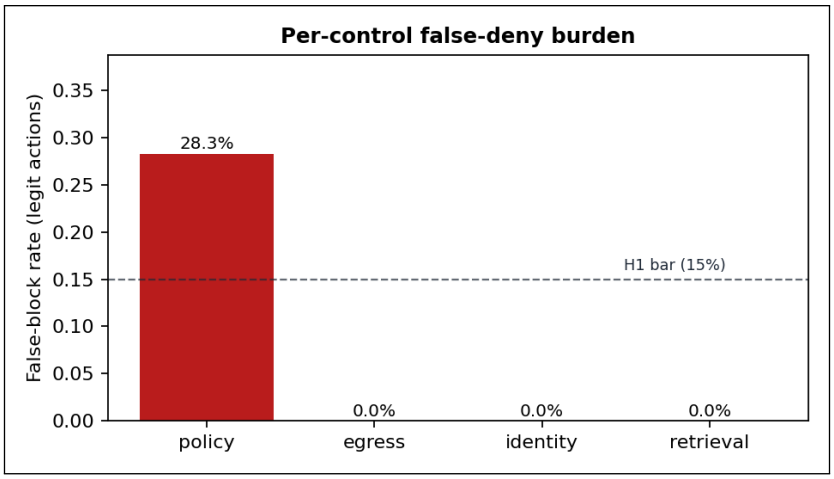


Figure 3: **Per-control false-deny burden (E1).** The policy control blocks 28.3% of safe actions; egress/identity/retrieval rarely fire on legit traffic. The false-block burden is the motivation for a calibrated escalation path.

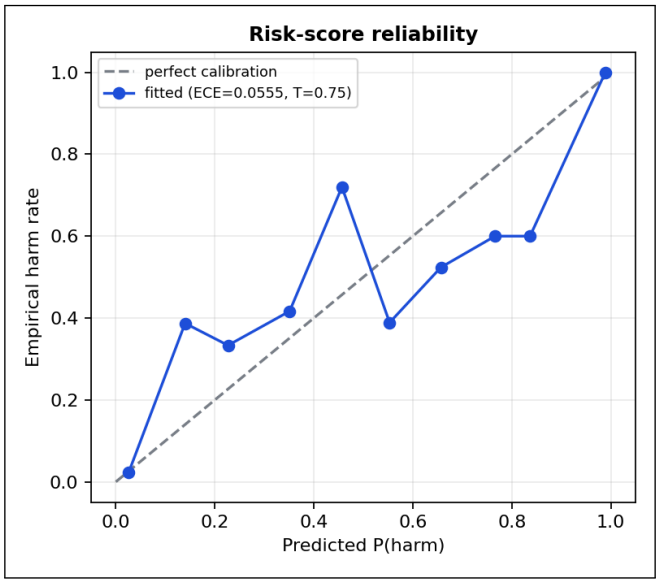


Figure 4: **Risk-score reliability (E2).** Predicted $P(\text{harm})$ vs. empirical harm rate for the fitted scorer; ECE 0.056 after temperature scaling.

5.4 Care-delay frontier (E4)

Sweeping the auto-allow shift traces a genuine frontier (Figure 5): missed harm rises from 12 to 50 as total time-to-care delay falls from 533 to 298 minutes. The recommended operating point (the fitted bands, shift 0) is the conservative anchor; deployers move right as their care SLA tightens.

5.5 Alarm fatigue shifts the optimum (E5)

Modeling the per-escalation cost as growing with clinician load, the utility-optimal auto-allow shift moves from 0.02 (low load) to 0.26 (load 50, Figure 6): under heavy load the system should shed escalations even at the cost of more false-allows. Static thresholds are therefore mis-set when load is ignored (H4).

Policy	Escalation volume	False-allow	False-block
Fixed (escalate > 0.5)	0.405	0.087	0.000
Calibrated (fitted bands)	**0.242**	**0.020**	0.005
Cost-sensitive	0.197	0.020	0.005

Table 3: Escalation policy comparison (E3). Calibrated dominates fixed on both volume and false-allow; cost-sensitive trades a little auto-deny for even less volume.

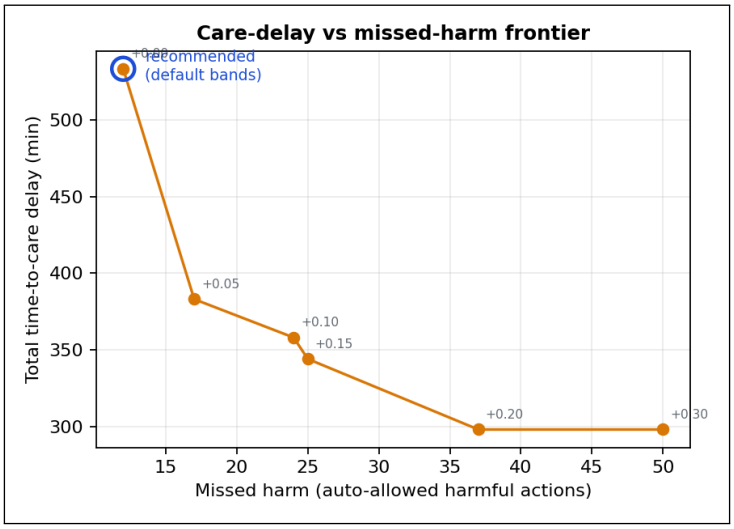


Figure 5: **Care-delay vs. missed-harm frontier (E4).** Each point is an auto-allow shift; the circled point is the recommended default.

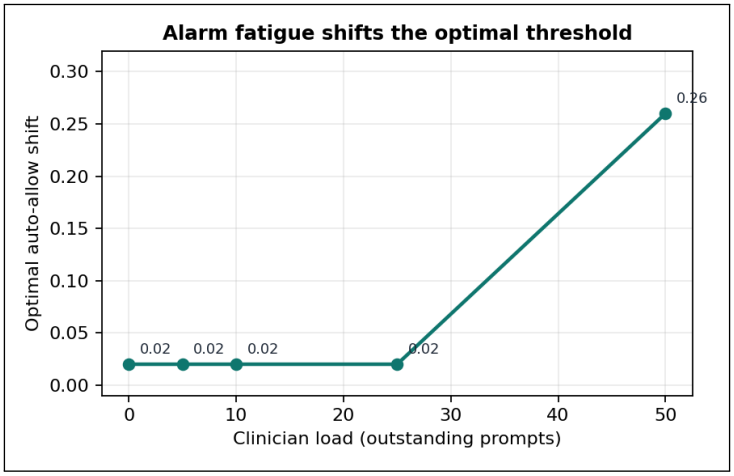


Figure 6: **Alarm fatigue (E5).** The optimal auto-allow shift increases with clinician load — the operating point is load-dependent.

5.6 Fitting matters: hand-set vs. fitted (ablation, E2/E3)

The same mechanism with *hand-set* weights yields ECE 0.229, only 16% volume reduction, and a degenerate alarm-fatigue curve (the optimum pinned at the cap). *Fitting* the calibration on TriageBench is what moves ECE to 0.056, H2 to 40%, and makes the load response non-degenerate. The mechanism is only as good as its calibration.

5.7 End-to-end (E6)

At the recommended config the full layer yields FA 0.020 (95% CI [0.011, 0.035]), FB 0.005 ([0.002, 0.018]), OE 0.242 ([0.210, 0.277]), and 533 minutes of preserved-care delay — the deployable summary point. Inter-rater reliability over the TriageBench labels is Fleiss' $\kappa = 0.81$ (substantial), so the decision boundary is empirically grounded.

6 Discussion and Limitations

Interpretation. Oversight is worth building only where automation is genuinely uncertain. The Pareto-domination result holds because a fitted, calibrated score confidently disposes of the easy cases, concentrating human attention on the ambiguous tail. This reframes "human-in-the-loop" from a blanket prompt into a targeted, costed routing decision.

Relationship to HAARF. `oversight` is the concrete realization of HAARF C4 (human oversight): it operationalizes the escalate path the prior controls defer (e.g. the `Escalate` effect introduced in quwarden), and its tickets are audited via C2 (quledger).

Limitations. (i) TriageBench is synthetic; the stealth/suspicious mix is hand-designed to be realistically ambiguous, not a measured clinical distribution, and the experts are simulated. External validity is bounded. (ii) The pre-registered $\geq$60% volume reduction was *not* reached (measured 40%); we report domination instead and do not tune to the target. (iii) The fit assigns `w_policy` a negative weight — an artifact of how the synthetic categories were drawn (suspicious-legit carry high policy margin, stealth attacks low), so policy margin anti-correlates with harm in *this* corpus; on real traffic the sign would differ. (iv) E1/E6 use TriageBench's embedded control signals as a stand-in for a live replay through the actual upstream modules. (v) Alarm fatigue is *modeled*, not measured in situ.

7 Conclusion

A gateway that can only allow or block is incomplete: over-blocking is a clinical hazard, and uniform escalation is alarm fatigue by another name. `oversight` adds a calibrated "ask a human" path that Pareto-dominates a fixed threshold — 40% fewer prompts at lower false-allow — and shows the operating point is load-dependent. The next step is to fit and validate the dial on real decision streams and to replace the modeled alarm-fatigue function with measured clinician response.

Declaration of generative AI use

During the preparation of this work the author used *Claude (Anthropic)* for drafting boilerplate, generating and debugging analysis and figure-plotting code, and language refinement. After using this tool, the author reviewed and edited the content and takes full responsibility for the publication. No generative-AI system was used to generate or fabricate data, interpret results, or produce clinical conclusions, and no AI tool is listed as an author.

Data and code availability

All code, datasets, scripts, and result artifacts are available at github.com/quome-cloud/qutriage. All data are synthetic; no real protected health information was used.

Competing interests

The author declares no competing interests.

Funding

This work received no specific external funding.

A Reproducibility

Every figure and number regenerates deterministically (seed 42):

```
python3 scripts/009-hitl-calibration/gen_triage.py
python3 scripts/009-hitl-calibration/fit_calibration.py
python3 scripts/009-hitl-calibration/run_experiments.py
python3 scripts/009-hitl-calibration/make_figures.py
cd papers/009-hitl-calibration && make paper
```

The Rust layer's tests (`cargo test --lib oversight` and `cargo test --test oversight_escalation`) cover the scorer, router, the park/resume/timeout primitive, and the Rust/Python calibration parity.

References

[1] Yonatan Geifman and Ran El-Yaniv. Selective classification for deep neural networks. In *Advances in Neural Information Processing Systems (NeurIPS)*, 2017.

[2] Jim Schwoebel, Martin Frasch, Art Spalding, Ed Sewell, Phil Englert, Ben Halpert, Collin Overbay, Ingrida Semenec, and Joel Shor. HAARF: Healthcare AI agents regulatory framework — a comprehensive security verification standard for autonomous AI systems in clinical environments. medRxiv preprint, https://doi.org/10.64898/2026.04.09.26350519, April 2026.

[3] Sue Sendelbach and Marjorie Funk. Alarm fatigue: a patient safety concern. *AACN Advanced Critical Care*, 24(4):378–386, 2013.